

Université Paul Sabatier — Toulouse III

Introduction à la Sécurité

Laure Bantsoukissa Emin Belkheir

Travaux Pratiques 4

Ping Sécurisé

1 Preuve de correction du protocole

1.1 Rappel du protocole

Le protocole de ping authentifié entre A et B s'écrit de la façon suivante :

1. $A \rightarrow B : \{A.N_a\}_{K_b}$
2. $B \rightarrow A : \{N_a.N_b\}_{K_a}$
3. $A \rightarrow B : \{N_b\}_{K_b}$

N_a et N_b sont les nonces créés pour la session, K_a et K_b sont les clefs publiques de A et B , et k_a^{-1} , k_b^{-1} leurs clefs privées respectives.

1.2 Tableau des connaissances

Le tableau ci-dessous retrace ce que chaque agent apprend à chaque étape du protocole. Les connaissances sont cumulatives.

TABLE 1 – Connaissances des agents au fil du protocole

Étape	A	B	Observateur O
Initialisation	$K_a, k_a^{-1}, K_b, \text{id}(A), \text{id}(B)$	$K_b, k_b^{-1}, K_a, \text{id}(A), \text{id}(B)$	$K_a, K_b, \text{id}(A), \text{id}(B)$
Avant envoi msg 1			
(A crée N_a)	$+ N_a$	—	—
Après envoi msg 1,			
avant réception	—	—	$+ \{A.N_a\}_{K_b}$
Après réception			
msg 1			
par B	—	$+ N_a$ (déchiffré via k_b^{-1})	—
Avant envoi msg 2			
(B crée N_b)	—	$+ N_b$	—
Après envoi msg 2,			
avant réception	—	—	$+ \{N_a.N_b\}_{K_a}$
Après réception			
msg 2			
par A	$+ N_b$ (déchiffré via k_a^{-1}),		
N_a vérifié	—	—	
Avant envoi msg 3	—	—	—
Après envoi msg 3,			
avant réception	—	—	$+ \{N_b\}_{K_b}$
Après réception			
msg 3			
par B	—	N_b confirmé (via k_b^{-1})	—

1.3 Qui peut construire le message 2 ?

Le message 2 est $\{N_a.N_b\}_{K_a}$. Pour le construire, il faut disposer de N_a et de N_b .

N_a est contenu dans le message 1, mais chiffré avec K_b . Seul B possède k_b^{-1} et peut donc le déchiffrer. L'observateur O voit bien passer le chiffré $\{A.N_a\}_{K_b}$ sur le réseau, mais il est incapable d'en extraire N_a sans la clef privée de B .

N_b quant à lui est créé par B juste avant l'envoi du message 2. Personne d'autre ne le connaît à ce stade.

Donc au moment où A reçoit le message 2, le seul agent qui pouvait l'avoir construit est B — à condition que les sessions soient isolées. On verra en partie 2 que ce n'est pas toujours le cas.

1.4 Qui peut construire le message 3 ?

Le message 3 est $\{N_b\}_{K_b}$. Il faut pour cela connaître N_b .

N_b est inclus dans le message 2, chiffré avec K_a . Seul A détient k_a^{-1} et peut donc récupérer N_b . L'observateur O voit passer le chiffré $\{N_a.N_b\}_{K_a}$ mais ne peut rien en faire.

Quand B reçoit le message 3 avec le bon N_b , seul A était en mesure de le produire — là encore, en supposant qu'il n'y a qu'une seule session en cours.

1.5 Limites de cette analyse

L'analyse ci-dessus montre que le protocole est correct dans le cas d'une session unique et isolée. Mais elle repose sur une hypothèse implicite : qu'un agent ne participe qu'à une seule session à la fois. Si un attaquant peut ouvrir plusieurs sessions en parallèle, il peut s'en servir pour faire déchiffrer des messages à son insu par un participant légitime. C'est exactement ce que le professeur a démontré en TP, comme on le voit dans la partie suivante.

2 Log et analyse de traces

2.1 Trace 1 — Session normale entre Laure et Emin

On commence par une session qui se déroule normalement, sans attaque. Emin est initiateur, Laure est répondeur. Les trois messages s'enchaînent correctement, les nonces sont bien vérifiées des deux côtés, et la session se termine avec succès.

```

bnl4244a@u6-104-06:~/secu/TP4$ ping_securise_initiateur Emin
Avec qui voulez-vous communiquer ?
Emin
bash: xxd : commande introuvable
envoi du nonce à Emin
uLt3qTP401aMXIscm7/dbkvsgmDvzkQhQunse6an6ATQJ0Re3JZM1uIYRSmzhKc1jeiW9g2u6oIIgpkj
KacKEIDhsT3K5NCm2IFRHyfbA+/kpazg60YmfCSbHsNFar20rjnvYhXzx0+embJ4AxCtkzSCLvlpBcB
jjE1/3hYB3F12bRPhATF7ZY+pUzUp3o2KVCs8Xe8JrS5NQX401NI679ejSBWqEpuywN4vBEqV+0F/dd
wV88qUPHYWtc8p7GPtZy2IOHMLf3cyFEh913SybI1TWGEb4e3S9iQzLyRdFcHzhp+lufxYj4TbM/kdu+
DFrIcA5ZHj2Y70ofd53kkg==
laure -> Emin : UDkdEMcwBwgzBjeGUk0RdhC5inlCzJYaT8coqRuH0m6mr6DrAcHsI2cd78g1p+NV
aR0Kot8Gdfm8gghom3wBiNeYWG5QKweA5oG6bbBKBBe9Jr92aIZS8d62HUrwcYThUE5+MY+UIrIJY+CA1
r/G3k/JbVvKXEkkg98vXsVGnAH3ncd4YT9GeN55Rh1/jldrU09jgfiGatzBzrSMRErT5YNhFG9dJmPEpS
NInHwSwx4diNkxWiEZbx4rtkA5vvOpWGPbhz/EYfCI9V/LimaFL/Q+iefwzPIldPjTHTV6uoejcxS18+
LERodCCei653l2/Zs7DhK6LFE/Xzkegf7jm3Ug==
nonce utilisé:
Quelle est la réponse ?
Emin -> Laure : XRdEG/NWM4EdDg0KKI7x51HPLmBwlC5Vm49WxDd792G8bMj9KUVisfzd57tguQ0H
nMrmaWVykn0o9ng9EUPU0ykmRVy1ooJ87y7uimkPnFh8vi6/p+QIJQ1+n0GZRGKv+l8yNGQMpIOeZ5mN
39SLVHobgXP49M/TBRqLbXql+703KEdPAEGiPwp0ASqTyrYz4TGhzZArvmfXj9xq7W5hCcUx8sqIit89
6fEQwcU9fM4ijGV10Qjgxm4X1ULveuMgSpXI5wgpXgYYrLRfvcUBDs8/hKkbD40MzaQ1CvZvdXIYZABD
DSvsKF5mo2//+lMjdWqhZ/+0lhNDsSPKZl5apA==
nonce renvoyé (à vérifier avant de répondre):
laure -> Emin : x19Nf6Z0so8WLFuhzi/MTS5BRw5GvjuTDxpA9lRI5vgTffpyIRbv5ze+HweUi/5J
9wrHp/7cWa48zv5SvYUwmtI4HFZuIo/qnkwwMb4UtFE9+gcUQGuf3/I9bwCc5LCMdTqDbFgEu/pokSpu
TMn65wFYhe65F1AxF+QtsUQ4IXFvSsLpXR3sDbpe3/d3m0x0nYjxCg8mCJHcE6fsQ2IpATqef9Klob7
B830tG+W9qmDX+3M1MxWu6QJdQ57t1PtX/245v+sDRnB9sN62zMXI8G+E2Fk8Ud65f3fA4PuZb7YeEN
4BSZI4gdIgYDP2m8QQQw/AnieeU3I3aTCegLRQ==
Exécution avec Emin terminée avec succès.

```

FIGURE 1 – Session ping sécurisé Laure – Emin, sans attaque

2.2 Trace 2 — Attaque par sessions parallèles (Usurpation d'identité)

Pendant le TP, le professeur a réussi à se faire passer pour Laure auprès de Rassoul en exploitant une faille du protocole. Il n'a pas cassé le chiffrement, mais a utilisé Laure comme un « oracle » pour déchiffrer les messages à sa place.

Déroulement concret de l'attaque :

1. **Laure** → **Prof** : $\{Laure.N_a\}_{K_{prof}}$ (Message 1 légitime).
2. Le **Prof** déchiffre avec sa clé privée et récupère N_a .
3. **Prof** → **Rassoul** : $\{Laure.N_a\}_{K_{rassoul}}$. Le Prof **rejoue** le message en changeant la clé de chiffrement pour se faire passer pour Laure auprès de Rassoul.
4. **Rassoul** → **Laure** : $\{N_a.N_b\}_{K_{laure}}$. Rassoul croit parler à Laure et lui envoie son défi. Le Prof ne peut pas lire ce message, il le transmet donc à Laure.
5. Le **Prof** copie ce message et l'envoie à Laure comme si c'était sa propre réponse (Message 2).
6. **Laure** → **Prof** : $\{N_b\}_{K_{prof}}$. Laure déchiffre le message de Rassoul sans le savoir et renvoie N_b au Prof, pensant finir l'échange avec lui.
7. **Prof** → **Rassoul** : $\{N_b\}_{K_{rassoul}}$. Le Prof récupère N_b , le re-chiffre pour Rassoul et complète l'échange.

Analyse de la faille

La faille réside dans le fait que le **Message 1** contient l'identité de l'émetteur (A) mais pas celle du destinataire (B) à l'intérieur du bloc chiffré.

Cela permet au Prof de récupérer un message chiffré pour lui et de le « re-chiffrer » pour n'importe qui d'autre (Rassoul) sans que personne ne s'en aperçoive. Pour corriger cela, il faudrait inclure l'identité du destinataire visé dès le départ, soit : $\{A.N_a.B\}_{K_b}$.